

Seguridad, Errores y HITL

Veronica Bibiloni — Coldwell Banker Seniority

El sistema está diseñado para ser **seguro** (minimiza y protege los datos), **resiliente** (no se cae ante fallos de API) y **controlado** (una persona aprueba antes de toda acción crítica). A continuación se detallan los tres pilares.

1. Minimización y protección de datos

Qué datos se guardan y cómo se protegen

- Solo se almacenan los datos necesarios para gestionar el lead (nombre, contacto, consulta y clasificación). No se recopila información sensible adicional.
- Las credenciales (API keys de OpenAI, Anthropic y Airtable) se guardan cifradas dentro de las conexiones de Make; nunca se escriben en los módulos ni se exponen en el flujo.
- En el video demo y la documentación, las API keys y credenciales se mantienen ocultas.
- El acceso a la base es mediante conexión OAuth autorizada; el dashboard se comparte como vista de solo lectura, sin permitir edición externa.

2. Rutas de error (resiliencia)

Manejo de fallos de API

- El módulo de IA (OpenAI) tiene un **manejador de errores** conectado: si la API falla (por ejemplo, key inválida o sin crédito), el flujo se desvía en lugar de romperse.
- El error se registra automáticamente en la tabla **Log de Errores** con el mensaje, el módulo afectado y la fecha, dejando trazabilidad.
- Prueba realizada (camino infeliz): se invalidó temporalmente la API key y el sistema registró el error '**[401] Incorrect API key provided**' en Log de Errores, sin detener el escenario. Evidencia incluida en el repositorio.
- Se evitan bucles infinitos: el trigger procesa solo correos no leídos y de a uno, y el filtro del Escenario 2 solo deja pasar los leads aprobados.

3. Human-in-the-Loop (punto de validación humana)

El sistema espera aprobación antes de contactar al cliente

- Tras clasificar el lead y redactar la respuesta, el sistema **NO contacta al cliente automáticamente**. Se detiene.
- Envía una notificación de aprobación por email con los datos del lead y la respuesta propuesta.
- La persona revisa y, si está de acuerdo, cambia el campo **Estado** del lead a '**Aprobado por humano**' en Airtable.
- Ese cambio dispara el Escenario 2, que —solo entonces, y solo para los leads aprobados (filtro)— envía la respuesta al cliente y marca el lead como 'Contactado'.
- Esto evita el 'efecto metralleta': ninguna comunicación sale sin control humano.

Checklist de seguridad verificado

Control	Estado
Filtro para evitar bucles infinitos (solo no leídos + filtro de estado)	Verificado
Comparación de tipos de datos correcta en los filtros (texto vs texto)	Verificado
Prompts de IA dinámicos, con variables del sistema (nada hardcodeado)	Verificado
Credenciales protegidas y ocultas	Verificado
Manejo de errores probado en vivo (camino infeliz)	Verificado